CHRIS RILEY

Training – the Security Minefield

Learning something new is a wonderful thing. However, with all the security training on offer right now, how do you know what's right for you ?

Over the past few years, I've been slowly re-inventing my career in an attempt to be more involved in security. Like many people, I fell into a role where I needed to implement and ensure security for existing systems. Installing a simple Intrusion Detection System, running vulnerability scans and even performing a few crude penetration tests to give those higher ups a visual representation of how our security was failing in some areas. Due to my circumstances however, I wanted to jump start this gradual change and go all-in. Over the course of 18 months I've been learning the ins and outs of security almost from scratch, using the framework from various recognized companies. This article is an overview of that process, and more importantly a view on where the different training available falls down. Nobody can say 100% that they know everything there is to know about security, that's for sure. The field is so young, yet already so diverse. Whether or not you work as a server administrator, or a full on penetration tester, at sometime you're going to want to get a little piece of paper that says you know your stuff.

To certify or not to certify, that is the question

Many people much smarter than me have debated and re-debated about the pros and cons of certification. Whether or not you choose to go for a certification in security is something that only you can decide. Personally, after working so long within the desktop and server support area, I wanted something that proved I could do more than just standard support. After all, if you take the plunge and start applying for security positions, the person sitting behind the big mahogany desk is going to want more than just your word that you can do the job. In my opinion, experience counts for a lot more than a piece of paper ever can. With that said, if you're like me and want to make the jump into security from a standard IT role, then one or more well placed qualifications are a step in the right direction. Sometimes you've got to walk before you can run after all.

The Security minefield

To give a varied overview of what training is available, I'll be discussing various types of training that I've had some personal experience with. Some of them are very general, like the CompTIA Security+. Others are more specific to a product line, were the Microsoft MCSE: Security is a prime example. In the middle of these two extremes I'll touch on the CIEH (Certified Ethical Hacker) and ECSA/LPT (EC-Council Certified Security Analyst/License Penetration Tester) offerings from EC-Council, as well as the Penetration Testing specific GPEN (GIAC Certified Penetration Tester) from the people at SANS. There are some others that I'm not yet able to cover, such as the OSCP

(Offensive Security Certified Professional) from the Offensive-Security team (the people behind the excellent Backtrack live CD), and the SSCP (Systems Security Certified Practitioner) from ISC². These are worth a mention, and may be something you'll want to look into if what we cover here doesn't quite fit your needs exactly. There are many other options I'm sure. Just like any part of the IT industry, a thriving market for security courses has sprung up around the security industry, offering a new qualification almost every month it seems. Hopefully this situation will sort itself out in time, with the clear leaders in the field becoming something akin to an industry standard, and the lower quality qualifications falling by the wayside. Before the mail starts to flow, I'll not be discussing the CISSP in this article. This is to keep the focus on the more technical courses for people working in the trenches so to speak. Although people may like to disagree, the CISSP is and always has been more focused on management level types. This isn't to say that the CISSP is not a valid exam. After all you can't turn the pages of a newspaper nowadays without seeing an advert for a CISSP. However, the CISSP has become, in my opinion, an easy solution for HR staff around the world. If in doubt, ask for a CISSP. This does little to split the technical and management sides of the security industry and just adds to the confusion. With these basics cleared up, on with the show.

CompTIA Security+

The Security+ certification is marketed as a vendor-neutral exam that tests knowledge in 5 main areas: Communication Security, Infrastructure Security, Cryptography, Operational Security, and General Security concepts. With over 50,000 members, the certification is well known in the industry and widely accepted as the entry point certificate. However well recognized, the CompTIA Security+ only gives you a very basic grounding in security concepts. The topics covered are well thought out, but in order to maintain its vendor-neutral status, it goes out of its way to talk in very general terms about topics without going too in-depth. Although the Security+ is very worthwhile, alone it does little more than show that you can incorporate security into your present role. This is certainly not a life changing event by any stretch of the imagination. If you plan to move onto more advanced topics, or more specific qualifications like the MCSE: Security (or the newer MCITP), then this is a good place to start. The theory will be of great help for the specialist topics found in these more focused qualifications.

There are a number of good books available for home study of the Security+ topics and I would personally suggest this as a better method than class driven training. The theory can become a little complex in parts, especially for those new to the field. The chance to go at your own pace and review parts at your own leisure makes the book method more flexible. I found the study time for the exam to be very short compared with some of the others listed here. If you really want to go for class training, I would suggest avoiding classes that rely solely on the Microsoft training manuals for teaching this class. As strange as it sounds, CompTIA has passed the Microsoft Official Curriculum – "Fundamentals of Network Security" (Course 2810), as suitable for teaching the Security+. The Microsoft curriculum is often used when the Security+ is taught together with the MCSE. I found this book to be very Microsoft centric and caused some confusion when covering topics that were supposed to be vendor-neutral.

The Security+ exam consists of 100 multiple choice questions over the space of 90 minutes. Although the number of questions seemed daunting at first, the questions were for the most part straight forward and not nearly as confusing as some of the Microsoft exam questions. Compared to other exams however, the cost is quite high. If you're not 100% sure you know your stuff, then this could be a costly exam to fail. CompTIA are currently working on an update version of the Security+ for release in October this year. If you plan to take the exam after this point, then you may want to check that your learning material covers everything in the new objectives as well as the existing ones.

Microsoft MCSE Security

As with all qualifications provided by Microsoft, they are very focused on achieving specific tasks the "Microsoft" way. This isn't always a bad thing, and learning how the people who made the software expect it to be done can be a great help in some areas. In others, it is painfully obvious that they are teaching topics just because they want you to use the product in a specific way. A prime example of this is a large section on using RRAS (Routing and Remote Access Services) as a router under Windows 2003 Server. Putting aside the fact that a reasonably spec'd server costs the same or more than a quality Cisco router. As well as the fact that on top of this hardware, you'll need to purchase a software license for Windows. The Windows RRAS service just doesn't offer the same level of service or quality that a real router provides. Thankfully this kind of content is restricted to only a few places within the MCSE and a majority of the topics are well formed and appropriate. The modular design of the MCSE leaves you some choice on what to study, while still maintaining a minimum level of knowledge through required exams. This flexibility allows you to pick and choose what you learn to meet with your specific needs. The MCSE is not for the faint at heart. Unlike the vendor-neutral Security+, you will need to learn about everything. Starting from the client-side systems and going all the way through to the Server-side, with ISA Firewalls and everything else in-between. This is level of detail is certainly not a bad thing, however it does add to the expense and overall time required to achieve the qualification. The knowledge gained along the way will seem like a hassle at times, but will stand you in good stead for any future work with Windows environments. As much as we'd all like to avoid that, it will happen sooner or later.

As I mentioned earlier, the Microsoft qualifications are extensive and it's best to plan to spread them out over a period of time. Each builds on the knowledge from previous exams, so if possible start at the beginning (Client-side) and work your way through to the more technical

subjects. This strategy unfortunately means that working from the client system, through the server fundamentals and advanced topics, leaves the security courses until the very end. It's a long road to travel, however Microsoft have generously paved the way with the MCP (Microsoft Certified Professional) and MCSA (Microsoft Certified Systems Administrator) qualifications. This means that you can begin to see the benefits of your training almost as soon as you begin to take exams. On the plus side, almost everyone looking for staff has heard of the Microsoft MCP or MCSE, so industry recognition is very high. It may not land you that job as a Security Analyst that you were looking for, but it could be the first step towards that goal. Another good thing about the MCSE is that you can apply your CompTIA Security+ to the MCSE Security specialism. This means that you will have one less Microsoft exam to take if you can work Security+ into the equation. This method means you'll be getting two qualifications for the price of one (well almost).

As the MCSE Security track is so long, encompassing 8 exams in total, it's hard to give advice on how to handle it. Personally I found a mixture of home learning and class study worked well for me. I began working with the technology and reading about it from the Microsoft Press books. It's important to have some kind of home lab (even a VMware lab is good enough for this purpose) as the exams all test your knowledge of not only the theory, but also expect you to be able to perform the tasks as well. Some of the exams have begun to include simulation questions were you have to perform a set task. These tasks are not overly complex, but do mean that just learning the theory won't get you far. Although many people swear by the Sybex books for most Microsoft topics, I found them to be unreliable for a number of the advanced topics in the MCSE. The Microsoft Press books certainly aren't cheap, and they don't seem to like the lighthearted approach to training. In fact, sometimes they can be downright boring. With that said however, they cover what you need in all its raw detail, which is what you need. Plus who better to know what you need to learn than the company that makes the rules in the first place. Once you get to some of the more advanced topics such as clustering, ISA Server, and possibly PKI, then you may want to start to look at the various class offerings around. It's not hard to learn the theory for these parts, but the setups become more difficult in a home lab environment. I'd stay clear of boot camp style learning, as from experience they just want to get you in and out as fast as they can. Learning is almost a secondary concern in some cases. If money is tight, then the videos from companies like CBTnuggets and VTC are also a very good resource to look into. Classroom style training, but at your own pace and budget.

CIEH – Certified Ethical Hacker

The CIEH has been much hyped over the past few years as THE ethical hacking certification. Even though the hype is still there, it's become clear that the CIEH is no longer the only show in town. It is certainly still worthwhile if you plan to go into the penetration testing or incident handling arenas. However there are now a range of other courses that rival this for top spot. I've personally found that some companies are still advertising for CIEH certified staff, however almost exclusively alongside other qualifications such as MCSE or Security+. This goes to prove that achieving a CIEH will not be the deciding factor in moving into security, but is instead a midway point of sorts. If you already have other qualifications, the CIEH helps you clarify your position and show that you know your stuff when it comes to hacker tools and techniques.

The CIEH course itself is very focused on hacker tools. In fact you could say that the entire course is about tools. Theory of how attacks work is given when required, but the tools are the bread and butter of this course. As with many hacking courses, the topics covered are sometimes more than a little outdated. Some topics covered even date back to NT4 in places, and as such are not always the most useful. The techniques are nice to know for historical reference, however the patches and upgrades to render these techniques useless have been in place for many years now. When I took the course late last year, I was very disappointed in the structure of the course in general and especially the course material. Usually I complain that the course material is too small and doesn't cover enough. However in the case of CIEH it was the exact opposite. Weighing in at over 2300 pages, it was very far from a small book. In fact, it was 4 large books. Having read through most of the course material (I had a free week over New Year) I can almost certainly say that the material could be slimmed down to less than half what it is now and as a result be much more learning friendly. I hate to think what the new CIEH material is like, as EC-Council claim to have increased the modules in the new version 6 classes. The speed at which the course was covered previously means that very little time is spent going into the fine detail. With more modules I'm not sure you'll have time to read the slides before moving onto the next.

If you have a basic understanding of hacker techniques and want some hands on time with the tools in class, then CIEH is a good place to start. Being able to use the tools against live test systems will always teach you more than reading an example in a book. I personally found that due to the extensive content covered in the course, not enough emphasis was put on the practical side. With more time spent rushing through the descriptions of what tools do than anything else. If you're a beginner to the ethical hacker game, then becoming a CIEH may not be as easy as it looks. When taking the exam I was surprised by the amount of questions that seemed not to have been covered in the exam material. You'd think that with 2300 pages to play with, they'd squeeze all the facts in somewhere, but no such luck. A good overall knowledge of IT and basic security theory is required before attempting the exam in my personal opinion. The exam was certainly harder than you would expect from the course content.

After taking the live training at an authorized center, I'd suggest that if at

all possible the home study method is more suited to the CIEH material. There are a number of books available for the CIEH version 5 exam, and hopefully these will be updated to cover the version 6 exam in the near future. EC-Council also offers some official CBT training. I've had the displeasure of sitting through this for a few hours, and can only say that it's a few hours of my life that I'd claim back if I could. The delivery is dry, almost as if it's read from a script, and the overall content is very poor. As an alternative there are a number of ethical hacking CBT's available from people like CBTnuggets and VTC which seem much more appropriate and informative. I found these videos very useful for a basic overview, but not enough to pass the exam without further study in specific areas. After all, watching a video is never as good as getting your hands dirty yourself. As with the MCSE, I would recommend spending some time with the tools in a lab environment using something like VMware. Some of the tools, especially Metasploit, are complex to learn at the fast pace you see them in class and take a while to truly master.

Once you've passed your CIEH, EC-Council requires that you retain your qualification by collecting ECE points. Although the system is relatively new and a little confusing, the collection of points is not hard to do. As long as you're actively learning (read security books, listening to security podcasts, etc...) then you should build up enough points without too much problem. The points system seems a little slanted in the favor of EC-Council, but it's beginning to even itself out. Going to an EC-Council sponsored event will still get you more ECE points than something like Defcon or Blackhat, but I'm sure this will change in the long run. Hopefully EC-Council will clarify the ECE points over the next few months and smooth out the system a little.

ECSA/LPT – EC-Council Certified Security Analyst / Licensed Penetration Tester

Hot on the heels of the CIEH comes the follow up course, ECSA. Whereas the CIEH spends most of its time dealing with hacker techniques, the ECSA deals with analysis side of security. Dealing with the analysis of vulnerabilities and threats, instead of the more attack focused CIEH. The LIPT portion is somewhat more confusing. In an attempt to set a standard in the penetration testing industry, EC-Council created the Licensed Penetration Tester status. To gain LIPT status, you need to take and pass both the CIEH, and ECSA exams. Once this is done you have to complete the LIPT workshop (included in the ECSA course) and pay $500 for membership (with $250 per year to retain your status). I'll touch more on the LIPT later.

The ECSA class reminded me a lot of the CIEH class, mostly because of the large books and surprising similarity in the slides and overall content. In fact one could say the ECSA was almost a CIEH plus in almost all respects. Although at times the content was almost identical, the focus was more from an analysis point of view and did help to clarify a number of open questions from the CIEH course. That said, I don't think that there was enough difference between the courses to warrant a second 5 day course. With some work the CIEH, ECSA and LIPT could easily be molded into a single course with the same content covered in a more focused manner. The exam, as with the CIEH was surprisingly hard compared to the contents of the course, and referenced a lot of the information taught in the CIEH course. I understand that the exam for ECSA has since been changed to reflect the analysis side of the course better and rely less on the CIEH material.

Training for the ECSA exam is not an easy proposition. Outside of the official courses and material, there appears to be no 3rd party books or CBT's based on the content of the course. This only leaves the official classes as the only viable option if you wish to achieve the ECSA or LIPT. I have asked EC-Council if they can provide only the learning material, but have yet to receive an answer on this request.

Compared to the CIEH, the ECSA/LPT is not very well recognized within the industry. To date I've not seen the ECSA or LIPT requested in job adverts and haven't seen many people advertising this qualification on their CV. At this time I don't think that the ECSA is worth the effort to achieve in its current state. Hopefully EC-Council will re-evaluate the course material in the next version and improve the content of the course to be more useful to future students. I felt disappointed at the end of this course and that's never a good sign.

LIPT, Licensed Penetration Tester. The LIPT is somewhat of an enigma. The CIEH and ECSA qualifications do not in themselves cover everything you'll need to know to be a penetration tester. They cover the legal side in part, and some of the tools used, but never really bring it all together. The LIPT workshop appears to be a 1 day re-hash of the CIEH processes to collect things into a makeshift testing methodology. However with so many other well publicized testing methodologies like OSSTMM or NIST 800-42 out there, the LIPT has failed to make any impact on the industry. Adding to that the cost of $500 for the membership and the continued $250 fee to retain the LIPT status, and I cannot personally recommend the LIPT as a worthwhile investment. I felt that it was almost hypercritical of me to become a licensed penetration tester when, at the time, I'd never even performed a penetration test inside a lab environment. However the EC-Council thinks that this is acceptable, and actively recruits users into the LIPT scheme. Now that I have achieved all requirements for the LIPT and work as a penetration tester I still refuse to apply for LIPT status. This is even after EC-Council emailed me to ask me why I hadn't applied. If you have a spare $500 and want to work as a penetration tester, then I can suggest a list of books to buy that will cost much less than $500 and give you much higher return on investment.

SANS GPEN – GIAC Certified Penetration Tester

Finally we come to the SANS/GIAC GPEN exam. If you want to work as a penetration tester then this is the exam that you want to have under your belt. SANS has always been known as an organization that offers focused and informative training in all areas of IT

Security. With such renowned lecturers as Ed Skoudis, Mike Poor and Stephen Northcutt, it's hard to go far wrong. The SANS Security 560 course is a 6 day class that covers everything you need to know to be an well rounded penetration tester, from legal issues, planning, scoping, through to the scanning, and exploitation of the systems being tested. To help reinforce the knowledge gained in the first 5 days of the course, the final day comprises of a capture the flag event. Working in teams you get a chance to use the techniques learned in the course in a real life simulation of a penetration test. I found this part of the course really helped me to bring it all together, and was well worth doing. The course was very well focused to cover the tools that you really need to know in order to perform tests, without the need to list 30 tools for each task like the CIEH class. In all I found the class to be one of the best I've attended and walked out a better penetration tester for attending. Having already used the knowledge I gained in the class, I can tell you that although the class isn't cheap, it's worth every penny. Alongside the technical side of the course, the people that you meet at the SANS events are a great resource. Sometimes it's not what you know, but who you know after all.

SANS offers courses in a variety of security disciplines, from incident handling through to forensic analysis. All of the classes are specifically tailored to what is required to get the job done well and right first time. With the training material written by people who are well known in the security industry, the courses are updated regularly to meet with the ever changing security landscape. This ensures that you get a first rate training experience, with knowledge that isn't already 2 years out of date, like some other courses. Once you've finished the course, access to MP3's from the course are available for review of the topics. There is also the option to have access to the OnDemand service which gives you a chance to go through the course again in full at your PC and at your own pace. The many options that SANS gives help to really reinforce the technical topics covered.

The course and certification are rather new to market (only available in the US since July), but are already being requested in job adverts Stateside. With the classes now being held in Europe as well as being available as a home study, it's only a matter of time before the same begins to happen across Europe as well. This course is not for the faint hearted however. From both a cost and content standpoint, it's hard to handle. The age old adage, you get what you pay for is certainly in full effect here. The cost for the course varies depending on where you take the course, however I found the course to be more than worth it in all aspects. SANS state that the course is "one of the most technically rigorous courses offered by the SANS Institute", and I can understand why. The content is well thought out, and covers a lot of things that other classes don't touch on. The organization of the classes was always first rate, and the content and trainers are always top notch. Due to the technical content of the course, this sort of qualification is something that needs to be built up to, and is certainly not your first stop on the Security ladder.

The GPEN exam is certainly no cake walk. I spent a long time studying and restudying certain aspects of the class before taking the two free practice exams provided. Although the exam is an open book (not open internet) exam, there is not enough time to look-up the answer to all of the 150 questions inside the 4 hour time limit set for the exam. This method of examination is in my opinion much more realistic than the style used by Microsoft and others. After all, if you forget which command switch nmap uses for UDP scans (-sU incase you were wondering) then most of us would just look it up in a book, or Google it. Sometimes it's more about knowing where to find the information, than actually knowing everything. To retain the qualification you will need to retake the exam once every 4 years. Although this may seem a little harsh, it does help to ensure that people with a GIAC qualification keep fresh on new techniques and methods. This is done to keep the certificate valid, and really helps to make the GPEN something special. With only about 22,000 GIAC certified individuals in total (not just GPEN), compared to more than a million people with an MCP, the GPEN is an altogether more prestigious group of individuals. If you want to stand out from the pack, this is the certification I'd choose.

Conclusion

With all the possible qualifications out there, it's important to figure out what you want to achieve and map out your chosen path clearly. You have to do your homework well before starting on the path to certification. With so many badly designed courses out there, and so many companies looking for your money, it's like a minefield. If there is one thing you should take away from this article, it's that there isn't a single path to follow when it comes to security qualifications. There are many options out there, many more than I could cover here. Where you choose to go, and how you get there are up to you. Classroom training isn't always the best option, sometimes you'll get more from reading a few good books than you will from spending weeks in a structured course. Figure out how you learn best, and run with it. But most of all have fun with it. Learning is meant to be fun after all.

On the 'Net

- *http://certification.comptia.org/security/* (CompTIA Security+)
- *http://www.microsoft.com/Learning/mcp/* (Microsoft certification)
- *http://www.eccouncil.org* (EC-Council)
- *http://www.sans.org* (SANS Institute)
- *http://www.giac.org* (GIAC)

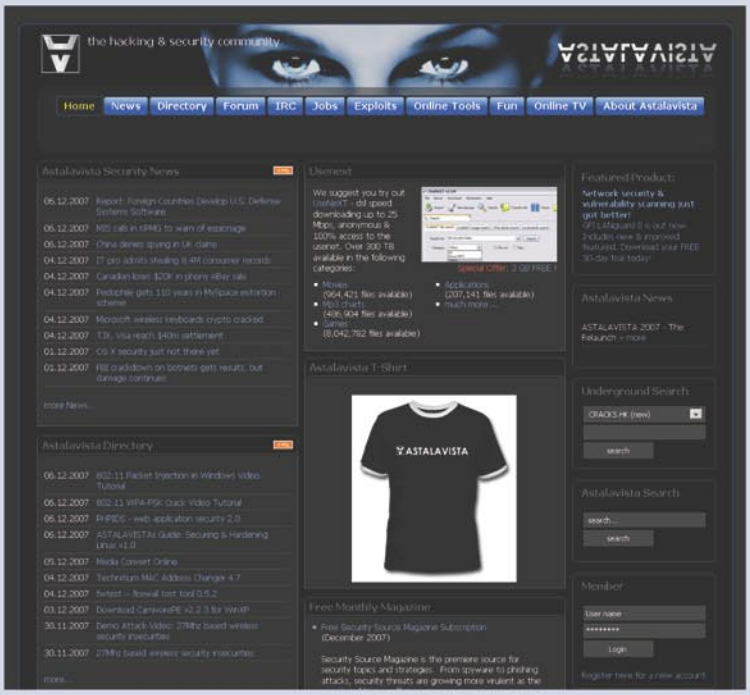
Chris Riley

Chris Riley is an IT Security Analyst living and working in Austria. He has been working in IT for over 12 years as a desktop and server administrator both in the UK and Germany. After relocating to Austria in mid-2007 he has reinvented himself as an Security Analyst and is presently working as a penetration tester for a leading Austrian bank. Chris is a member of the SANS advisory board and is looking to work as a SANS Mentor in the near future. In his spare time Chris blogs about security and can be reached through his website www.c22.cc

ASTALAVISTA RELAUNCH

the hacking & security community

As a member you will enjoy ...



>> Latest Security News
Astalavista.com provides you with the latest computer security news, information, vulnerabilities and white papers.

>> Industry leading Directory
Our website hosts the largest internet resource on hacking and security: Regularly updated tools, articles, ebooks, movies and more.

>> The Search
Searching is a big part of the internet. We offer you an index with the best specialised searchsites in different categories. Whatever you are searching for, you will find it.

>> Online Tools
The latest online and applications that exist in the hacking and security community from the shared ressources of all Astalavista members.

join for free on www.astalavista.com and be a part of the community

Astalavista.com
the hacking & security community